

Implementing OpenSSF Scorecards Across an Organisation



All Day DevOps - Oct 2023



openssf scorecard 8.2



OpenSSF Scorecards

Following the example set by [Dart and Flutter](#) we've implemented [Open Source Security Foundation Scorecards](#) on key repos:

Repo	OpenSSF scorecard
at_app	openssf scorecard 7.1
at_client_sdk	openssf scorecard 8.1
at_demos	openssf scorecard 7.8
at_java	openssf scorecard 7.7
at_libraries	openssf scorecard 8.2
at_protocol	openssf scorecard 8
at_server	openssf scorecard 8.2
at_tools	openssf scorecard 8.2
at_widgets	openssf scorecard 8
dess	openssf scorecard 7.5
docs.atsign.com	openssf scorecard 8.2
mwc_demo	openssf scorecard 7.8
sshnoports	openssf scorecard 7.5



Hi, I'm Chris

@cpswan

<https://chris.swanz.net>



Agenda

- Who are OpenSSF, and what is a scorecard?
- Start with Allstar
- Doing your first repository
- Scaling across multiple repositories
- 80:20
- The toil of it all



Who are OpenSSF,
and what is a scorecard?

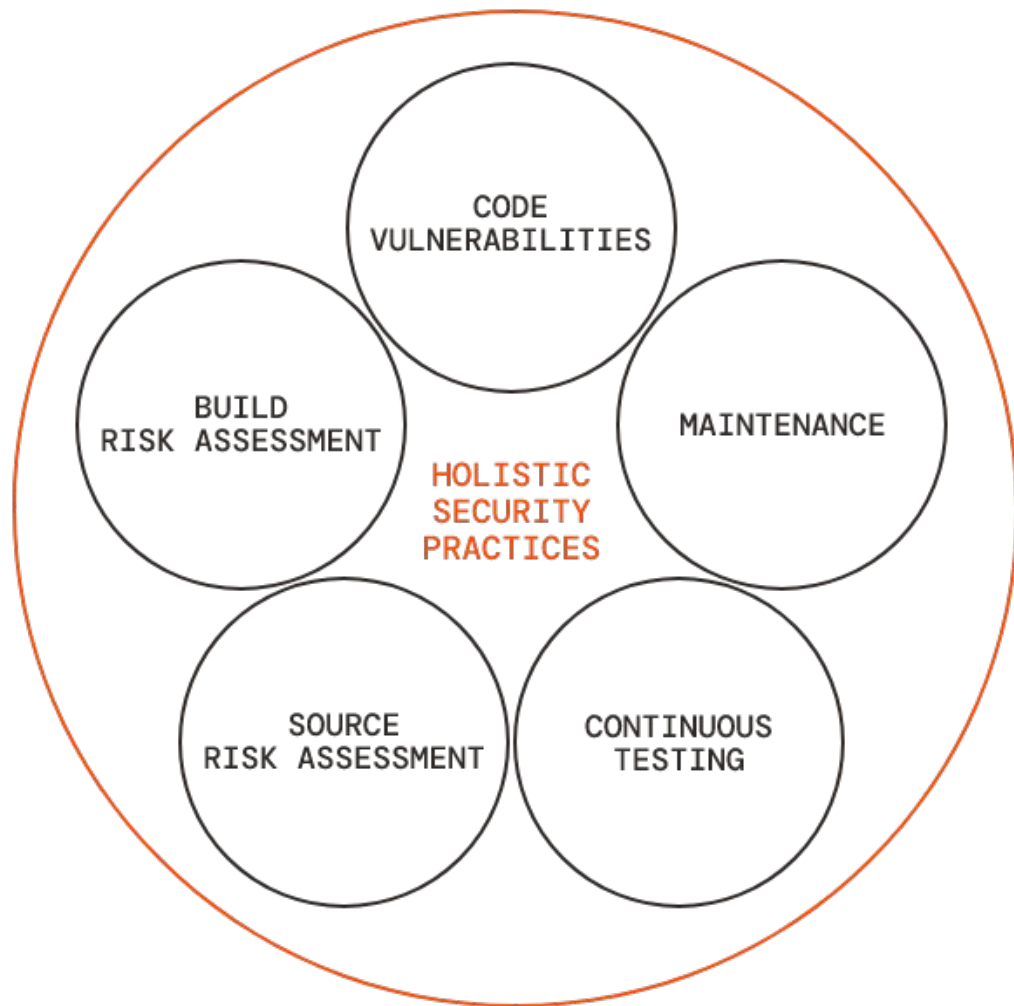


OpenSSF

OPEN SOURCE SECURITY FOUNDATION

<https://openssf.org/>





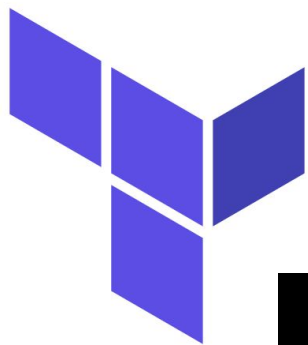
Start with Allstar



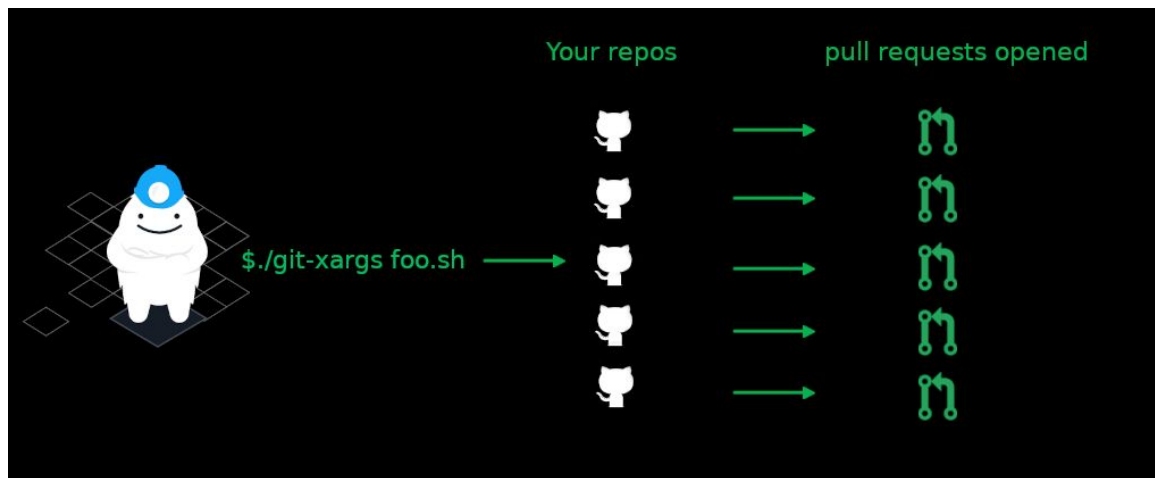
<https://github.com/ossf/allstar>



A whole bunch of config, and a whole bunch of files



Terraform



Doing your first repository

Expect LOTS of issues

The screenshot shows a list of GitHub Actions workflow runs. The top bar indicates '128 Closed' runs. The list includes runs for 'Branch-Protection', 'Token-Permissions', and 'Pinned-Dependencies'. A large red box highlights the word 'Closed' in the background, and a smaller red box highlights the '128 Closed' status in the top bar.



Help is at hand



Apply Security Best Practices

☆ Star

189

- ☒ Restrict permissions for GITHUB_TOKEN
- ☐ Add security agent for GitHub-hosted runner
- ☒ Pin actions to a full length commit SHA

Paste your GitHub Actions workflow in the editor below, click this button, and then copy the output

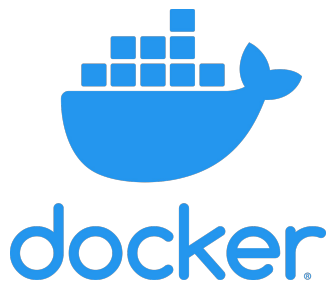
➔ SECURE WORKFLOW

🔗 CREATE A PULL REQUEST



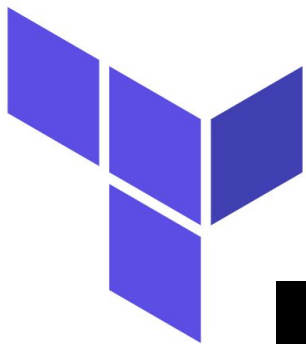
```
11+ permissions: # added using https://github.com/step-security/secure-repo
12+ contents: read
13+
14 jobs:
15   build_multi_arch_images:
16     runs-on: ubuntu-latest
17     steps:
18       - name: Check out code
19         uses: actions/checkout@v3
20         uses: actions/checkout@8e5e7e5ab8b370d6c329ec480221332ada57f0ab # v3.5.2
21       - name: Set up QEMU
22         uses: docker/setup-qemu-action@v2.1.0
23         uses: docker/setup-qemu-action@e81a89b1732b9c48d79cd809d8d81d79c4647a18 # v2.1.0
24       - name: Set up Docker Buildx
25         uses: docker/setup-buildx-action@v2.5.0
26         uses: docker/setup-buildx-action@4b4e9c3e2d4531116a6f8ba8e71fc6e2cb6e6c8c # v2.5.0
27       - name: Login to DockerHub
28         uses: docker/login-action@v2.1.0
29         uses: docker/login-action@f4ef78c080cd8ba55a85445d5b36e214a81df20a # v2.1.0
30       with:
31         username: ${{ secrets.DOCKERHUB_USERNAME }}
32
33 ✓ Minimum GITHUB_TOKEN permissions have been set. [Learn more]
34 ✓ GitHub Actions have been pinned to their full length commit SHA. [Learn more]
35 ✓ Permissions already defined at the workflow level.
```

Dependency (pinning) hell cont...

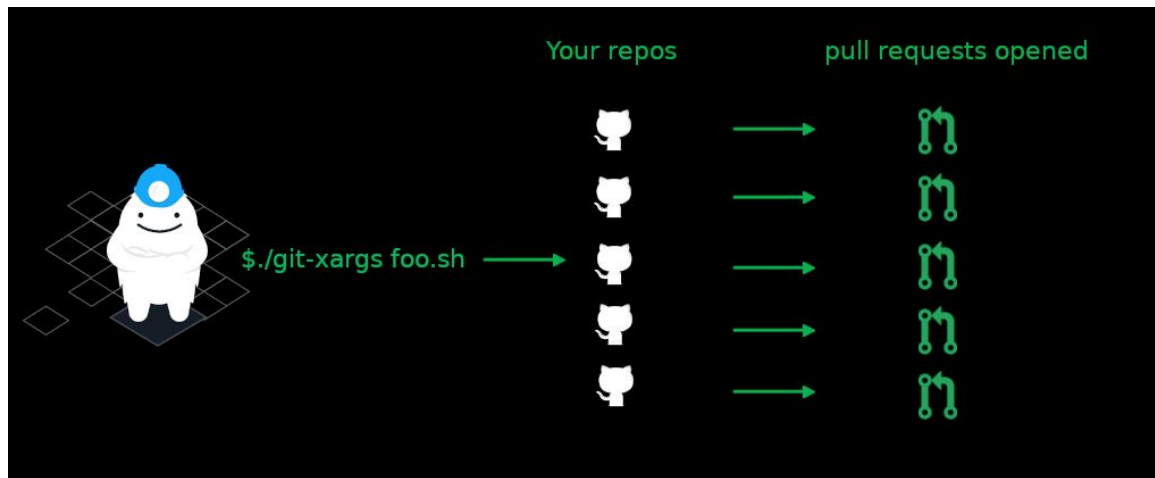


Scaling across multiple repositories

Rinse and repeat - more of this



Terraform



And more of this



Apply Security Best Practices



189

- ☒ Restrict permissions for GITHUB_TOKEN
- ☐ Add security agent for GitHub-hosted runner
- ☒ Pin actions to a full length commit SHA

Paste your GitHub Actions workflow in the editor below, click this button, and then copy the output

➔ SECURE WORKFLOW

🔗 CREATE A PULL REQUEST



```
11+ permissions: # added using https://github.com/step-security/secure-repo
12+ contents: read
13+
14 jobs:
15   build_multi_arch_images:
16     runs-on: ubuntu-latest
17     steps:
18       - name: Check out code
19         uses: actions/checkout@v3
20         uses: actions/checkout@8e5e7e5ab8b370d6c329ec480221332ada57f0ab # v3.5.2
21       - name: Set up QEMU
22         uses: docker/setup-qemu-action@v2.1.0
23         uses: docker/setup-qemu-action@e81a89b1732b9c48d79cd809d8d81d79c4647a18 # v2.1.0
24       - name: Set up Docker Buildx
25         uses: docker/setup-buildx-action@v2.5.0
26         uses: docker/setup-buildx-action@4b4e9c3e2d4531116a6f8ba8e71fc6e2cb6e6c8c # v2.5.0
27       - name: Login to DockerHub
28         uses: docker/login-action@v2.1.0
29         uses: docker/login-action@f4ef78c080cd8ba55a85445d5b36e214a81df20a # v2.1.0
30       with:
31         username: ${{ secrets.DOCKERHUB_USERNAME }}
32
33 ✓ Minimum GITHUB_TOKEN permissions have been set. [Learn more]
34 ✓ GitHub Actions have been pinned to their full length commit SHA. [Learn more]
35 ✓ Permissions already defined at the workflow level.
```

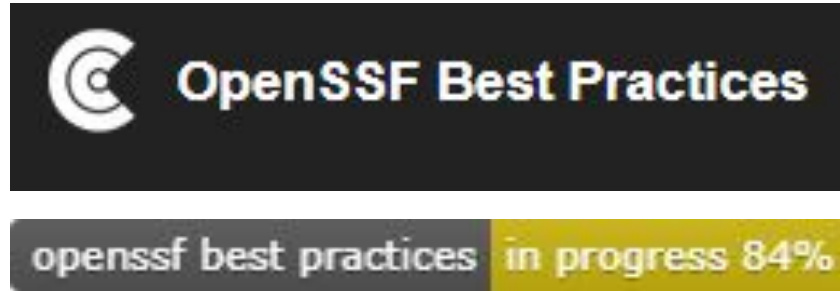
80:20

There will be a residue

☐  3 Open		☒ 2 Closed	Tool ▾ Branch ▾ Rule ▾ Severity ▾ Sort ▾	
☐		SAST	Medium	trunk
#4 opened 5 months ago • Detected by Scorecard in no file associated with1				
☐		Fuzzing	Medium	trunk
#3 opened 5 months ago • Detected by Scorecard in no file associated with1				
☐		CII-Best-Practices	Low	trunk
#2 opened 5 months ago • Detected by Scorecard in no file associated with1				



This is where it gets really gnarly



▼ Basics	13/13 ●
▼ Change Control	8/9 ●
▼ Reporting	8/8 ●
▼ Quality	11/13 ●
▼ Security	14/16 ●
▼ Analysis	2/8 ●



The questionnaire is long and detailed

New functionality testing



- ☐ Met
☐ Unmet
☐ ?

The project MUST have a general policy (formal or not) that as major new functionality is added to the software produced by the project, tests of that functionality should be added to an automated test suite. [\[test_policy\]](#) [Show details](#)



- ☐ Met
☒ Unmet
☐ ?

The project MUST have evidence that the [test_policy](#) for adding tests has been adhered to in the most recent major changes to the software produced by the project. [\[tests_are_added\]](#) [Show details](#)



- ☐ Met
☒ Unmet
☐ ?

It is SUGGESTED that this policy on adding tests (see [test_policy](#)) be *documented* in the instructions for change proposals. [\[tests_documented_added\]](#) [Show details](#)



And some sections might be hard to accomplish

Dynamic code analysis



- ☐ Met
- ☐ Unmet
- ☒ ?

It is SUGGESTED that at least one dynamic analysis tool be applied to any proposed major production release of the software before its release. [\[dynamic_analysis\]](#) [Show details](#)



- ☐ Met
- ☐ Unmet
- ☐ N/A
- ☒ ?

It is SUGGESTED that if the software produced by the project includes software written using a memory-unsafe language (e.g., C or C++), then at least one dynamic tool (e.g., a fuzzer or web application scanner) be routinely used in combination with a mechanism to detect memory safety problems such as buffer overwrites. If the project does not produce software written in a memory-unsafe language, choose "not applicable" (N/A). [\[dynamic_analysis_unsafe\]](#) [Show details](#)



- ☐ Met
- ☐ Unmet
- ☒ ?

It is SUGGESTED that the project use a configuration for at least some dynamic analysis (such as testing or fuzzing) which enables many assertions. In many cases these assertions should *not* be enabled in production builds. [\[dynamic_analysis_enable_assertions\]](#) [Show details](#)



- ☐ Met
- ☐ Unmet
- ☐ N/A
- ☒ ?

All medium and higher severity exploitable vulnerabilities discovered with dynamic code analysis MUST be fixed in a timely way after they are confirmed. [\[dynamic_analysis_fixed\]](#) [Show details](#)



The toil of it all

Make friends with the new boss



From a docs repo (no actual code to maintain)

- ☐  **build(deps): bump actions/checkout from 3.5.1 to 3.5.2** ✓ dependencies
#71 by dependabot  was merged on Apr 13 • Approved
- ☐  **build(deps): bump github/codeql-action from 2.2.11 to 2.2.12** ✓ dependencies
#70 by dependabot  was merged on Apr 13 • Approved
- ☐  **build(deps): bump actions/checkout from 3.5.0 to 3.5.1** ✓ dependencies
#69 by dependabot  was merged on Apr 12 • Approved
- ☐  **build(deps): bump github/codeql-action from 2.2.10 to 2.2.11** ✓ dependencies
#68 by dependabot  was merged on Apr 7 • Approved
- ☐  **build(deps): bump github/codeql-action from 2.2.9 to 2.2.10** ✓ dependencies
#67 by dependabot  was merged on Apr 5 • Approved



From a code repo

- ☐  build(deps): bump dart from 2.19.1 to 2.19.2 in /tools/build_secondary ✓ dependencies docker
#1193 by dependabot (bot) was merged on Feb 9 • Review required
- ☐  build(deps): bump dart from 2.19.1 to 2.19.2 in /packages/at_root_server ✗ dependencies docker
#1192 by dependabot (bot) was merged on Feb 9 • Review required
- ☐  build(deps): bump dart from 2.19.1 to 2.19.2 in /tools/build_virtual_environment/ve ✗ dependencies docker
#1191 by dependabot (bot) was merged on Feb 9 • Review required
- ☐  build(deps): bump dart from 2.19.1 to 2.19.2 in /tools/build_virtual_environment/ve_base ✓ dependencies docker
#1190 by dependabot (bot) was merged on Feb 9 • Review required
- ☐  build(deps): bump github/codeql-action from 2.2.2 to 2.2.3 ✓ dependencies github_actions
#1189 by dependabot (bot) was merged on Feb 9 • Approved
- ☐  build(deps): bump github/codeql-action from 2.2.1 to 2.2.2 ✓ dependencies github_actions
#1188 by dependabot (bot) was merged on Feb 7 • Approved
- ☐  build(deps): bump docker/setup-buildx-action from 2.4.0 to 2.4.1 ✓ dependencies github_actions
#1187 by dependabot (bot) was merged on Feb 7 • Approved
- ☐  build(deps): bump debian from bullseye-20230109 to bullseye-20230202 in /tools/build_virtual_environment/ve_base ✓ dependencies docker
#1186 by dependabot (bot) was merged on Feb 6 • Review required
- ☐  build(deps): bump dart from 4c77cf9 to 86d317e in /tools/build_virtual_environment/ve_base ✓ dependencies docker
#1185 by dependabot (bot) was merged on Feb 6 • Review required
- ☐  build(deps): bump dart from 4c77cf9 to 86d317e in /packages/at_root_server ✓ dependencies docker
#1184 by dependabot (bot) was closed on Feb 6 • Review required
- ☐  build(deps): bump dart from 4c77cf9 to 86d317e in /tools/build_virtual_environment/ve ✓ dependencies docker
#1183 by dependabot (bot) was closed on Feb 6 • Review required
- ☐  build(deps): bump dart from 4c77cf9 to 86d317e in /tools/build_secondary ✓ dependencies docker
#1182 by dependabot (bot) was closed on Feb 6 • Review required
- ☐  build(deps): bump google-github-actions/setup-gcloud from 1.0.1 to 1.1.0 ✗ dependencies github_actions
#1181 by dependabot (bot) was merged on Feb 6 • Approved



Dockerfiles need rollups

- ☐  **build(deps): bump dart from 2.19.1 to 2.19.2 in /tools/build_secondary** ✓ dependencies docker
#1193 by dependabot bot was merged on Feb 9 • Review required
- ☐  **build(deps): bump dart from 2.19.1 to 2.19.2 in /packages/at_root_server** ✗ dependencies docker
#1192 by dependabot bot was merged on Feb 9 • Review required
- ☐  **build(deps): bump dart from 2.19.1 to 2.19.2 in /tools/build_virtual_environment/ve** ✗ dependencies docker
#1191 by dependabot bot was merged on Feb 9 • Review required
- ☐  **build(deps): bump dart from 2.19.1 to 2.19.2 in /tools/build_virtual_environment/ve_base** ✓ dependencies docker
#1190 by dependabot bot was merged on Feb 9 • Review required



rollup.sh

```
#!/bin/bash
if [ $# -ne 2 ] ; then
    echo "Usage rollup.sh <BASE_PR> <LAST_PR>"
    exit 1
fi
BASE_PR=$1
LAST_PR=$2
git pull
gh pr checkout "$BASE_PR"
for (( i=$((BASE_PR + 1)); i<=LAST_PR; i++ ))
do
    PR_BRANCH=$(gh pr view "$i" --json headRefName -q .headRefName)
    git merge origin/"$PR_BRANCH" -m \
        "build(deps): Rollup merge branch for #${i} ${PR_BRANCH}"
done
git push
```



Scorecard's own dependencies can change with annoying regularity (in every repo with a scorecard)

☐  build(deps): bump github/codeql-action from 2.2.2 to 2.2.3 ✓ dependencies github_actions
#1189 by dependabot  was merged on Feb 9 • Approved

☐  build(deps): bump github/codeql-action from 2.2.1 to 2.2.2 ✓ dependencies github_actions
#1188 by dependabot  was merged on Feb 7 • Approved



Base dependencies can be amplified

- ☐  build(deps): bump debian from bullseye-20230109 to bullseye-20230202 in /tools/build_virtual_environment/ve_base ✓ dependencies docker
#1186 by dependabot bot was merged on Feb 6 • Review required
- ☐  build(deps): bump dart from 4c77cf9 to 86d317e in /tools/build_virtual_environment/ve_base ✓ dependencies docker
#1185 by dependabot bot was merged on Feb 6 • Review required
- ☐  build(deps): bump dart from 4c77cf9 to 86d317e in /packages/at_root_server ✓ dependencies docker
#1184 by dependabot bot was closed on Feb 6 • Review required
- ☐  build(deps): bump dart from 4c77cf9 to 86d317e in /tools/build_virtual_environment/ve ✓ dependencies docker
#1183 by dependabot bot was closed on Feb 6 • Review required
- ☐  build(deps): bump dart from 4c77cf9 to 86d317e in /tools/build_secondary ✓ dependencies docker
#1182 by dependabot bot was closed on Feb 6 • Review required

Review

- An OpenSSF Scorecard can show you care about security.
- Allstar provides a good starting point.
- Pick a first repo to get a hang of what's needed.
- Then automate across the rest of the organisation.
- 20% of the effort to get 80% of the score. Uphill from there.
- Scorecards do create ongoing toil that needs to be minimised.



Call to action: Run the scorecard CLI against one of your own repos

<https://github.com/ossf/scorecard#scorecard-command-line-interface>



Resources

Blog posts

<https://blog.thestateofme.com/2022/12/02/implementing-ossf-scorecard-s-across-a-github-organisation/>

<https://blog.thestateofme.com/2023/03/09/roll-up-rollup-get-your-dependabot-prs-together-here/>

atGitHub

<https://github.com/atsign-foundation/github/blob/trunk/docs/atGitHub.md>

Varun Sharma's (Step Security) QCon Demo Org

<https://github.com/qcon-demo-org>



Thanks for your time

chris@atsign.com

@cpswan



Questions?